

Respuesta a la Auditoría Técnica

Contraste entre los hallazgos del informe de Sparkpath Digital (Milestone 1) y el trabajo realizado

PREPARADO POR
casadelcuenco · RESONANCIA

EN RESPUESTA A
Technical Audit Report — Sparkpath Digital

FECHA
18 de agosto de 2026

RESUMEN EJECUTIVO

De los 15 hallazgos del informe de auditoría, **13 están completamente resueltos**, incluyendo los 3 críticos y todos los de severidad alta y media salvo dos. Cada resolución fue verificada directamente contra el código actual, no contra intención de trabajo. Quedan dos frentes acotados propios de la fase de submission.

3/3 CRÍTICOS RESUELTOS	13 HALLAZGOS RESUELTOS	0 PARCIALMENTE RESUELTOS	2 PENDIENTES
------------------------------	------------------------------	--------------------------------	-----------------

1 · SUBSISTEMA DE AUDIO

HALLAZGO DE LA AUDITORÍA	SEVERIDAD	ESTADO	QUÉ SE HIZO
Motor gapless existente conviviendo con un fallback de timers JS propenso a deriva	CRÍTICO	RESUELTO	El fallback de reloj JS fue eliminado por completo. <i>bpmAudioEngine</i> es hoy la única ruta para loops BPM: la inicialización se garantiza (con deduplicación) antes del primer tap, eliminando la carrera de arranque en frío. Se borró todo el código del scheduler paralelo.
Crossfade artesanal duplicado en mezclador y reproductor de sesiones	CRÍTICO	RESUELTO	El crossfade artesanal del reproductor de sesiones fue eliminado. Las sesiones de loop (<i>LOOP_SESSIONS</i>) suenan ahora íntegramente por <i>bpmAudioEngine</i> , con el reproductor expo-audio actuando como ancla

muda para la pantalla de bloqueo. No existe ningún crossfade de timers JS en ninguna ruta de reproducción.

Cambio de sesión como carrera suprimida por guardas, no resuelta

ALTO

RESUELTO

Implementado un token de generación de reproducción (*mainPlayerGenRef*) que sella cada llamada a *replace()*: el listener nativo descarta en el hilo de UI cualquier evento de una generación anterior, eliminando la carrera por diseño. El guard *switchingRef* permanece como segunda línea de defensa.

El timer de sueño puede no detener el audio con la pantalla bloqueada

ALTO

RESUELTO

Aplicación unificada y a prueba de segundo plano en **ambos** reproductores (mezclador y sesiones): marca de tiempo absoluta + verificación dentro del listener nativo de reproducción (que sigue corriendo con pantalla bloqueada) + recuperación al volver la app al frente. El intervalo JS quedó solo como actualización visual.

2 · DATOS Y SINCRONIZACIÓN

HALLAZGO DE LA AUDITORÍA

SEVERIDAD

ESTADO

QUÉ SE HIZO

Tablas sociales sub-indexadas para sus patrones reales de consulta

ALTO

RESUELTO

Se añadieron 15 índices a las tablas sociales: feed (visibilidad + fecha), ranking por likes, autor, comentarios por mezcla y por autor, likes por usuario y mensajes por fecha, más el par simétrico para consultas bidireccionales de amistades (solicitante y destinatario con estado) y mensajes directos (par inverso del hilo de conversación). Aplicados en base de datos.

El contador desnormalizado de likes puede divergir de la verdad

MEDIO

RESUELTO

Like/unlike corre en una transacción con bloqueo de fila (*FOR UPDATE*) y el contador se **recalcula desde las filas reales** dentro de esa misma transacción — no puede divergir.

Restricción de unicidad garantiza un like por usuario.

Contenido creado por el usuario vive solo en almacenamiento local

MEDIO

RESUELTO

Todo el contenido creado por el usuario se respalda ahora en el servidor: carpetas, playlists y carpetas de favoritos (snapshot con GET/PUT dedicados y sincronización automática con debounce), y se sumaron los **presets del mezclador** y las **creaciones de Geometrix** al mismo snapshot, con actualización parcial por campo (cada módulo sincroniza lo suyo sin pisar al resto) y recuperación por unión en la primera sincronización de cada dispositivo.

Integraciones de terceros requieren un pase de seguridad

MEDIO

RESUELTO

El webhook de reservas (Cal.com) verifica firma HMAC-SHA256 sobre el cuerpo crudo con comparación de tiempo constante, rechaza peticiones sin firma válida, y es idempotente por identificador de evento (upsert). La moderación pasó de un flag oculto a un panel dedicado con roles (admin / moderador) y flujo de ocultar/eliminar.

3 · SISTEMA DE RACHAS

HALLAZGO DE LA AUDITORÍA	SEVERIDAD	ESTADO	QUÉ SE HIZO
La racha mostrada a todos los usuarios era un valor de prueba fijo	CRÍTICO	RESUELTO	Los overrides de depuración fueron eliminados. Cada usuario ve su racha real, calculada desde su actividad.
La animación de fuego descrita no existía en Inicio	ALTO	RESUELTO	Implementada: el fuego reposa atenuado y se enciende con animación al cumplir la meta diaria, con compuerta de una vez por día, más un flujo de celebración de día de racha e hitos. La regla que enciende el fuego es la misma que cuenta la racha (fuente única), evitando la divergencia que advertía la auditoría.

La lógica de racha vivía dentro de una pantalla monolítica; otras superficies podían calcular versiones propias

ALTO

RESUELTO

Cálculo extraído a un módulo compartido único que consumen todas las superficies vía un hook unificado, y elevado además al servidor: existe un endpoint autoritativo de racha (con zona horaria del usuario) con fallback local. Ninguna pantalla calcula su propia versión.

4 · GEOMETRIX, BUILD Y ARQUITECTURA GENERAL

HALLAZGO DE LA AUDITORÍA	SEVERIDAD	ESTADO	QUÉ SE HIZO
Lag de Geometrix: animaciones corriendo fuera de pantalla	ALTO	RESUELTO	Exactamente la línea que recomendaba la auditoría: todas las animaciones se pausan/cancelan al perder foco la pestaña, el carrusel solo monta la categoría activa (evita decenas de tiles animados), los gestos de alta frecuencia corren íntegros en el hilo de UI, y el componente pesado quedó memoizado. El lag global reportado desapareció sin necesidad de migrar a Skia.
Pantallas de apariencia terminada respaldadas por datos placeholder	ALTO	PENDIENTE	La pantalla de actividades presenciales sigue alimentada por un arreglo fijo. Antes del envío a tiendas se conectará a datos reales o se retirará del release, según lo recomendado.
Pipeline de build correcto pero envío a tiendas sin configurar	MEDIO	PENDIENTE	Los perfiles de build siguen sanos y se generan builds de desarrollo con normalidad. Credenciales de envío (iOS/Android) siguen pendientes de configurar; corresponde a la fase de submission.
Patrones de mantenibilidad: archivos muertos, fuente ausente, pantallas monolíticas	MEDIO	RESUELTO	Eliminados los archivos .bak y las versiones abandonadas de pantallas; la fuente referenciada (Manrope) quedó instalada y aplicada globalmente. Las pantallas monolíticas más críticas fueron

descompuestas (racha extraída a módulo propio, carrusel de Geometrix memoizado en componente independiente, código duplicado de audio eliminado). Código muerto y rutas muertas barridas.

REFUERZOS ADICIONALES (FUERA DEL INFORME ORIGINAL)

Trabajo de endurecimiento realizado en el mismo período, alineado con el espíritu de la auditoría:

1. **Likes de mensajes de comunidad:** autenticación obligatoria + idempotencia por usuario (un like por usuario por mensaje, con bloqueo de fila).
2. **Paginación** en catálogo, seguidores, seguidos y amigos, con límites defensivos.
3. **Caché de likes coherente** en la app: el corazón y el contador se ven iguales en detalle, carruseles y listas filtradas.
4. **Panel de administración:** 47 rutas auditadas (todas con autenticación y rol), validación de entradas ampliada con esquemas en las rutas de videos, etiquetas, secciones y moderación de mezclas.
5. **Verificación de tipos del servidor en verde:** corregido el error que mantenía roja la barrera de typecheck, restaurando la red de seguridad para cambios futuros.

PRÓXIMOS PASOS PROPUESTOS

1. **Actividades presenciales** — conectar a datos reales o retirar del release inicial.
2. **Configuración de submission** — credenciales de App Store / Play Store para el envío.
3. **Limpieza de código** — eliminar pantallas muertas y código duplicado de forma incremental antes del release.